

Target Recon & OSINT

Passive Reconnaissance, Social Media, SSL Analysis, Metadata, Breach Data & Professional OSINT Tools

Prepared for: Muhammad Shafiq Goraya

Track: Red Team / Penetration Testing

Style: Plain explanations, real-world examples, hands-on practicals, no quiz format

Covers: What passive reconnaissance actually is, social media OSINT, company website and job listing recon, SSL/cryptographic flaw discovery, breach data lookups, file metadata analysis, Google hacking, theHarvester, Wayback Machine, Shodan, GitHub, recon-ng, and MITRE CWE/CVE resources

Passive Recon

OSINT

Social Media Recon

SSL / TLS Analysis

Breach Data

Metadata

Google Hacking

theHarvester

Shodan

recon-ng

CWE / CVE

WHAT'S INSIDE

- Lesson 1 — What Is Target Recon?
- Lesson 2 — Passive Recon Fundamentals
- Lesson 3 — Recon via the Company Website
- Lesson 4 — Social Media OSINT
- Lesson 5 — Cryptographic Flaws & SSL/TLS Analysis
- Lesson 6 — Public Data & Breach Data
- Lesson 7 — File Metadata Recon
- Lesson 8 — robots.txt and sitemap.xml
- Lesson 9 — Google Hacking Database
- Lesson 10 — theHarvester
- Lesson 11 — Wayback Machine, Shodan & GitHub
- Lesson 12 — recon-ng Framework
- Lesson 13 — MITRE CWE & CVE Resources
- Practical Lab Exercises
- Final Summary + Keyword Grid + Homework

Lesson 1 · What Is Target Recon?

When an organization hires a penetration testing company, that organization becomes the "target" of the engagement. If the assessment is a black box test — meaning you're attacking from the outside in, just like a real threat would — the first job is to learn everything you can about that target before touching anything technical.

Key Idea

Target recon is about figuring out what information is freely available on the internet that the organization is already giving away, but which could still be used against them in an attack. Most of this falls under passive reconnaissance — gathering information without directly interacting with (or alerting) the target's systems.

Why This Doesn't Feel Like "Hacking" Yet

Unlike scanning or exploitation, this phase can feel closer to research than hacking — reading public web pages, checking social media, browsing job postings. But every piece of information gathered here shapes how the rest of the engagement is planned, including what social engineering pretexts might work and which technical systems deserve the closest attention later.

Lesson 2 · Passive Recon Fundamentals

Passive recon means gathering information without running scans that would provoke or alert the target — no loud, active probing yet. If any tooling is used at this stage, it's usually to automate the collection of publicly available information, not to interact directly with target systems in an intrusive way.

What You're Looking For

- **Technical and administrative contacts** — people whose names and roles are published because the organization wants to be contacted about their services or products.
- **Hosting information** — whether the target is cloud-hosted or self-hosted on-premises, and which specific provider they use.
- **Company reputation** — their known security stance. Are they known for being security-conscious ("bank vault tight"), or have they had public security problems in the past?

Why Reputation Matters

A company's known security history gives you a sense of how much work you may have ahead of you — a company with a track record of past breaches may have unresolved weaknesses, while a company known for strong security practices may require far more careful, creative reconnaissance to find any opening at all.

Lesson 3 · Recon via the Company Website

A huge amount of useful information can be gathered just by using a normal web browser and exploring the target's own website carefully.

The About Page and Team Pages

An "About" page often lists team members, sometimes with short bios — giving you real names and roles inside the organization. This is exactly the kind of personal information that could later be used in a social engineering pretext.

Careers and Job Listings

Example

A careers page might list an open position for a "Full Stack Software Professional," with the listing specifically mentioning the technologies used — for example Haskell, JavaScript, and Terraform. This tells an attacker exactly what technology stack the company builds its products on, which narrows down what vulnerabilities and known issues might actually be relevant to research.

Job boards outside the company's own site — like Indeed, Monster, and LinkedIn — often repeat and expand on this same kind of information, sometimes including even more technical contact details for who to reach out to about a role.

Key Idea

None of this required bypassing any security control. It's publicly published information, offered because the company wants to attract talent and customers — but it's still extremely useful reconnaissance data for an attacker building a picture of the target.

Lesson 4 · Social Media OSINT

Social media is one of the richest sources of open source intelligence (OSINT) available, precisely because people tend to share so much of their lives publicly.

What Employees Accidentally Reveal

Example

An employee might post a photo showing their new company laptop and badge, captioned "Just started here, so excited!" From this single post, an attacker can learn: the person's real name (now linked to the target organization), the operating system their laptop runs, and what their employee badge looks like. All of this builds credibility for a later social engineering attempt — the attacker can now reference real names, real details, and things that genuinely match what an insider would know.

Organizational Social Media Presence

It's not just individual employees — organizations themselves maintain LinkedIn profiles, YouTube channels, Instagram accounts, and more, because they want visibility for their brand. An attacker uses these same channels to learn about the organization's people, products, and processes, gaining the same kind of credibility-building detail as with individual posts.

Practical Takeaway

This is exactly why organizations run security awareness training around social media habits. The goal isn't to make people paranoid — it's to make them aware of how ordinary, well-meaning posts can quietly build an attacker's toolkit.

Lesson 5 · Cryptographic Flaws & SSL/TLS Analysis

Most systems and services rely on some form of encryption — web browsers, SSH, and more, each potentially using different encryption schemes. The important questions are: what type of encryption is actually being used, is it strong or weak, and are there known vulnerabilities tied to that specific type?

Common SSL/TLS Misconfigurations

- Certificates that have expired without being renewed
- Certificates that were revoked but never properly replaced
- Older, vulnerable versions of SSL/TLS still being supported

Practical Tool — ssllscan

```
ssllscan itpro.tv
```

Running this checks what type of SSL/TLS the target supports and cross-references known weaknesses. In a real demonstration, this revealed that a target was not vulnerable to Heartbleed, had TLS compression disabled, and supported TLS fallback to SCSV — but it also revealed support for a wide range of protocol versions: SSLv2, SSLv3, and TLS 1.0 through 1.3.

Why Supporting Old Protocols Is Risky

Supporting older, weaker protocol versions alongside newer ones creates room for downgrade attacks — where an attacker forces a connection to use the weaker, more exploitable version instead of the strongest one available. Combined with a man-in-the-middle position, this can open the door to attacks like key extraction. Even where an automated scanner doesn't flag every issue by name (as with the niche "Raccoon" attack affecting TLS 1.2 in this example), knowing exactly which protocol versions are supported lets a tester manually research whether any known, relevant vulnerabilities apply.

Key Takeaway

Automated tools are a starting point, not the final word. Understanding what the tool's output actually means — and doing additional manual research from there — is what separates a junior tester from a senior one.

Lesson 6 · Public Data & Breach Data

Organizations often publish data — brochures, whitepapers, downloadable booklets — without necessarily realizing everything that data might reveal, such as who created it, what tools were used, or whether it contains unintentionally sensitive information.

Checking for Known Data Breaches

Example — Have I Been Pwned

A site like Have I Been Pwned lets you check whether a specific email address or password has appeared in any known data breach. Searching a target organization's domain can reveal a list of breaches associated with that company, including what type of data was exposed — email addresses, IP addresses, passwords, and more.

Dark Web Password Dumps

Beyond public breach-checking tools, stolen credential data sometimes circulates for sale on the dark web. An attacker who finds a password dump tied to a target's domain — even one they have to pay a small amount for — can build a targeted wordlist of real, previously-used passwords specific to that organization, which is often far more effective than a generic wordlist.

Why This Matters for Defense Too

This is exactly why breach-monitoring and mandatory password resets after known incidents matter so much — old, breached credentials remain useful to attackers indefinitely unless they're explicitly invalidated.

Lesson 7 · File Metadata Recon

Publicly available documents — PDFs, Word documents, spreadsheets — often carry hidden metadata that can reveal usernames, software versions, and operating systems used to create them.

Practical Tool — Metagoofil

```
metagoofil -d itpro.tv -t pdf,txt,xml,doc,docx,xls -e 200 -w
```

Here, `-d` specifies the target domain, `-t` lists the file types to search for, `-e` sets a delay (in this case 200 milliseconds) between search requests, and `-w` tells the tool to download every file it finds.

Why the Delay Matters

Since these tools often search via Google by default, running requests too quickly can get you temporarily blocked by Google's own anti-automation protections (like a WAF). Finding a delay value that avoids triggering this — while still completing in a reasonable time — is a practical skill in itself.

Example — What Metagoofil Might Find

In a real run, this technique uncovered an installation manual for a thermal door device, a POS entry/user registration guide, and several XML files — revealing hardware and processes the organization uses that weren't otherwise publicly announced.

Practical Tool — ExifTool

```
exiftool document.docx
```

Running ExifTool against a downloaded document can reveal details like the software used to create it and the operating system version — for example, a document created as a Microsoft Word file on macOS 10.14. Seeing a pattern of documents all created on the same operating system can help an attacker decide which platform to focus vulnerability research on later.

Lesson 8 · robots.txt and sitemap.xml

Two small, often-overlooked files can reveal a surprising amount about a website's structure.

robots.txt

This file is meant to tell search engine crawlers which parts of a site they should not index. Ironically, this makes it a useful recon target — by definition, it lists paths the organization doesn't want casually discovered, such as unusual directories or demo pages, which are exactly the kind of thing worth investigating further.

sitemap.xml

A sitemap file is meant to help search engines understand a site's full structure. For a tester, it can reveal pages and sections that might not be obviously linked from the main navigation — for example, old event-specific pages or documentation for internal projects.

Key Idea

Neither of these files is a vulnerability by itself. They're simply maps — but maps are exactly what reconnaissance is trying to build.

Lesson 9 · Google Hacking Database

The Google Hacking Database is a curated collection of specialized search queries ("Google dorks") designed to surface specific types of information — exposed files, login portals, vulnerable devices, and more — using nothing but carefully crafted search engine queries.

Example

One category of dork specifically targets pages containing login portals for a particular piece of software — for example, a specific open-source game panel. Running that targeted search against a domain of interest can reveal login portals for that exact software, if the target happens to use it — all without ever touching the target's servers directly.

Why This Is Powerful

Google Dorks let you search for extremely specific patterns across the entire indexed web — far beyond a plain keyword search — turning a general-purpose search engine into a reconnaissance tool.

Lesson 10 · theHarvester

theHarvester is an automation tool built specifically to collect information like email addresses and contact details from a range of public sources at once.

```
theHarvester -d company.com -b google,yahoo,bing
```

Here `-d` specifies the target domain, and `-b` specifies which sources to search across (a wide range of engines and platforms are typically supported).

Why Email Addresses Matter

Discovered email addresses are often a strong hint at an organization's username format (for example, `firstname.lastname@company.com`), which becomes directly useful later for password attacks or phishing-based social engineering attempts.

Lesson 11 · Wayback Machine, Shodan & GitHub

The Wayback Machine

Sometimes sensitive information exists only in older, previously published versions of a target's website. The Wayback Machine (part of Archive.org) keeps historical snapshots of websites, letting you browse how a site looked in the past — occasionally revealing information that was removed from the current live site for good reason.

Shodan

Shodan is a search engine for internet-connected devices rather than web pages. Searching a target's IP address on Shodan can reveal which ports are open (for example, 80 and 443), and which cloud provider is hosting the system — building further understanding of the target's technical footprint without directly scanning it yourself.

GitHub

Company-run GitHub repositories can contain a surprising range of information — sometimes including code comments, configuration files, or even accidentally-committed credentials. Checking whether an organization runs public GitHub repositories, and reviewing what's in them, is a standard part of thorough reconnaissance.

The Common Thread

Each of these three tools looks at the target from a completely different angle — historical web content, exposed devices, and code repositories — which is exactly why professional recon uses several sources together rather than relying on just one.

Lesson 12 · recon-ng Framework

recon-ng is a dedicated framework for organizing and automating reconnaissance work, rather than a single-purpose tool. It helps keep everything gathered during an engagement organized in one place, and can run automated modules to collect additional data.

```
recon-ng
workspaces create itprotv
workspaces list
marketplace info all
marketplace install all
```

You start by creating a workspace specific to your current target (here, `itprotv`), which keeps all gathered data organized separately from other engagements. The marketplace contains modules — small, focused tools for specific recon tasks — which can be browsed, installed, and then run individually as needed.

Why a Framework Matters

As reconnaissance data grows — contacts, subdomains, breach data, metadata findings — keeping it organized in a structured workspace is far more sustainable than scattering notes across text files. This becomes especially valuable in longer engagements or when working as part of a team.

Lesson 13 · MITRE CWE & CVE Resources

CWE — Common Weakness Enumeration

CWE is a community-developed list of common software and hardware weakness types. Once you've identified what hardware or software a target is using (through the recon techniques above), you can check CWE to see whether that category of technology has any commonly known weakness patterns associated with it.

CVE — Common Vulnerabilities and Exposures

CVE, maintained by the same MITRE organization, catalogs specific, individually identified vulnerabilities and exposures — much more granular than CWE's general weakness categories. Once you know a target's exact software and version (again, from earlier recon steps), CVE lets you check for specific, documented vulnerabilities tied to that exact product.

How CWE and CVE Relate

Think of CWE as the general category of mistake (for example, "improper input validation"), and CVE as a specific, real-world instance of that mistake in a named product and version. Recon work earlier in this document — technology stack from job listings, SSL details, file metadata — is what tells you which CWE categories and CVE entries are even worth checking in the first place.

Practical Lab Exercises · Hands-On Target Recon

These exercises let you practice the techniques above safely. Always perform active steps (like `ssllscan` or `metagoofil` against a live server) only against domains you own or are explicitly authorized to test — most of the exercises below can otherwise be done using entirely passive, publicly available sources.

Lab 1 — Website Recon Walkthrough

Pick any public company website (your own, or one you're authorized to study) and manually find: the About/Team page, any published bios, the Careers page, and at least one job listing that mentions specific technologies. Write down every technology name you find.

Lab 2 — Social Media OSINT Practice

Search for the same company's official pages on LinkedIn, YouTube, and one other platform. Note what kind of information (employee names, technologies, office locations, recent projects) is visible without logging in or connecting.

Lab 3 — SSL/TLS Scan

On a domain you own or are authorized to test, run:

```
sslscan yourdomain.com
```

List every protocol version it reports as supported, and note whether any of them (SSLv2, SSLv3, early TLS versions) are considered outdated or risky today.

Lab 4 — Breach Data Check

Visit Have I Been Pwned and search a domain or email address you're authorized to check (such as your own). Record what breaches, if any, are associated with it, and what type of data was exposed in each.

Lab 5 — Metadata Extraction

Download a public PDF or Word document from any organization's website, then run:

```
exiftool document.pdf
```

Record what metadata is revealed — creation software, author name, or operating system, if present.

Lab 6 — robots.txt and sitemap.xml Review

Visit <https://example.com/robots.txt> and <https://example.com/sitemap.xml> for a domain you're authorized to review. List any paths or pages that seem unusual or worth further investigation.

Lab 7 — Google Dork Practice

Browse the Google Hacking Database and pick two categories relevant to a technology stack you identified in Lab 1. Try running one relevant dork query and note what kind of results it returns.

Lab 8 — Set Up recon-ng

Install and launch recon-ng, create a workspace for a practice target, and browse the marketplace module list. Install one module and read its description to understand what data it collects.

Reminder

Passive techniques (website browsing, social media, Wayback Machine, Have I Been Pwned, Google dorks) carry very low risk when used responsibly. Active techniques (sslscan, metagoofil against a live server, theHarvester with live source queries) should only be run against systems you own or have explicit written permission to test.

Final Summary · What You've Learned in This Module

- What target recon is, and why it forms the foundation of a black box penetration test
- The difference between passive recon (no target interaction) and the tools that automate collecting public information
- How a company's own website — About pages, team bios, and job listings — reveals technology stacks and personnel names
- Why social media is one of the richest OSINT sources, and how ordinary posts can build attacker credibility
- How to check for cryptographic and SSL/TLS misconfigurations using sslscan, and why supporting old protocol versions is risky
- How to check for known data breaches using Have I Been Pwned, and why dark web password dumps matter
- How to extract hidden metadata from public documents using Metagoofil and ExifTool

- Why robots.txt and sitemap.xml are useful recon targets, not just crawler instructions
- How Google Dorks and the Google Hacking Database turn a search engine into a recon tool
- How theHarvester automates email and contact discovery across multiple sources
- How the Wayback Machine, Shodan, and GitHub each reveal a different layer of a target's footprint
- How recon-ng organizes and automates the entire reconnaissance process
- How MITRE's CWE and CVE resources connect discovered technologies to known weakness categories and specific vulnerabilities

The Full Keyword List

Passive Recon	OSINT
ssllscan	Heartbleed
Have I Been Pwned	Metagoofil
ExifTool	robots.txt
Google Dorks	theHarvester
Wayback Machine	Shodan
recon-ng	CWE
CVE	

Homework (15 minutes)

Without looking at your notes, explain these topics in simple English, in your own words:

- Why job listings on a company's own website can be valuable reconnaissance data
- Why supporting old SSL/TLS protocol versions alongside new ones creates risk
- What Have I Been Pwned tells you, and why dark web password dumps matter even more
- What kind of information ExifTool can reveal about a document that you can't see just by opening it
- Why robots.txt can accidentally help an attacker instead of stopping one
- The difference between CWE and CVE, and how they relate to each other

If you can teach these topics to someone else in simple English, you have truly understood them. Get some rest — you've earned it.